



Er din virksomhed GDPR-compliant?

Brug denne tjekliste til at identificere huller i jeres databeskyttelse. Hvert punkt repræsenterer en central GDPR-forpligtelse for små og mellemstore virksomheder i EU. 1 point pr. afkrydsning.

1. Lovligt grundlag & gennemsigtighed

- ☐ **Vi har identificeret et lovligt behandlingsgrundlag for hver type personoplysning vi behandler**
Samtykke, kontrakt, legitim interesse eller retlig forpligtelse — ét af disse skal gælde.
- ☐ **Vi har en klar og tilgængelig privatlivspolitik på vores hjemmeside**
Skal forklare hvilke data I indsamler, hvorfor, og hvor længe I opbevarer dem.
- ☐ **Vi informerer registrerede ved indsamlingen om hvordan deres data bruges**
Privatlivsnotits på formularer, e-mailtilmeldinger eller kontrakter — ikke kun gemt i politiksidens.
- ☐ **Vi indhenter og dokumenterer udtrykkeligt samtykke hvor det kræves**
Samtykke skal være frivilligt, specifikt, informeret og utvetydigt — og kunne dokumenteres.

2. Datakortlægning & dataminimering

- ☐ **Vi har en fortegnelse over alle personoplysninger vi behandler (artikel 30-register)**
GDPR Artikel 30 kræver at organisationer dokumenterer deres behandlingsaktiviteter.
- ☐ **Vi indsamler kun personoplysninger der er strengt nødvendige for det angivne formål**
Undgå at indsamle data "for en sikkerheds skyld" — kun det I faktisk har brug for.
- ☐ **Vi har defineret en opbevaringsperiode for hver type personoplysning**
Data må ikke opbevares længere end nødvendigt for formålet.



3. Registreredes rettigheder

☐ **Vi har en proces til at håndtere indsigtsanmodninger inden for 30 dage**

Den registrerede kan anmode om kopi af sine data — I skal svare inden for én måned.

☐ **Vi kan slette eller berigtige personoplysninger på anmodning**

Retten til at blive glemt og retten til berigtigelse.

☐ **Vi har en proces til at håndtere indsigelser mod databehandling**

Den registrerede kan gøre indsigelse mod behandling baseret på legitim interesse.

4. Sikkerhed & databrud

☐ **Vi har passende tekniske sikkerhedsforanstaltninger på plads**

Kryptering, adgangskontrol, stærke adgangskoder og regelmæssige backups.

☐ **Vi har en skriftlig procedure for håndtering af databrud**

Brud skal anmeldes til Datatilsynet inden for 72 timer hvis de udgør en risiko.

☐ **Adgang til personoplysninger er begrænset til autoriserede medarbejdere**

Anvend least privilege-princippet — adgang gives kun hvor det er nødvendigt.

☐ **Vi anvender stærke adgangskoder og MFA på systemer der indeholder personoplysninger**

En basal men kritisk kontrol — og i stigende grad et krav fra cyberforsikringer.

5. Tredjeparter & dataoverførsler

☐ **Vi har underskrevne databehandleraftaler med alle tredjeparts databehandlere**

CRM, e-mailudbydere, regnskabssystem, cloud-lager — alle leverandører der håndterer persondata.

☐ **Overførsler til tredjelande (uden for EU/EØS) har et gyldigt overførselsgrundlag**

Standardkontrakter (SCCs), tilstrækkelighedsafgørelse eller anden Artikel 46-foranstaltning.

Hvordan scorede du?

13–16 Stærkt fundament Book et opkald og få lukket de sidste huller

8–12 Tydelige huller Bør håndteres snart

0–7 Høj risiko Kontakt os for en prioriteret vurdering

Ved du ikke hvor du skal starte?

Book et gratis 20-minutters møde. Vi gennemgår jeres situation og fortæller jer ærligt hvad der bør gøres — ingen jargon, ingen forpligtelser.

calendly.com/hello-soroflow/20min →

